

JanGyan — Learn Without Limits

Category : Cyber Safety & Digital Security

Module 3 - Password & Authentication

Module Overview

This handbook is your complete, beginner-to-advanced guide to **Password & Authentication** — how to create genuinely strong passwords, why password managers matter, how Two-Factor and Multi-Factor Authentication (2FA/MFA) protect you, and how to stay safe from India's fastest-growing fraud tactic: OTP theft. Whether you're securing your first email account or your family's banking apps, this handbook gives you everything you need in one place.

By the end of this module, you will not need to search anywhere else to understand how to lock down your digital accounts properly.

Learning Objectives

After completing this module, you will be able to:

- Create strong, memorable passwords using current best-practice guidance
- Understand what a password manager does and why experts recommend using one
- Explain the difference between 2FA and MFA, and choose the strongest option available
- Recognise how OTP fraud works and avoid becoming a victim
- Understand India's evolving rules on digital payment authentication
- Apply practical account-security habits immediately
- Know exactly where and how to report authentication-related fraud

---

Why This Topic Matters

Credential theft — stolen or guessed passwords and OTPs — remains the single most common way attackers break into personal and business accounts. In India, scammers have industrialised OTP theft through tactics like **call-merge fraud**, phishing links, and fake customer-care calls, draining accounts in seconds once an OTP is shared.

> *Reality Check: Cybercrime losses in India were projected to cross ₹20,000 crore in 2025, with credential and OTP-based fraud among the leading causes — while in parallel, the Reserve Bank of India has made Two-Factor Authentication compulsory for every digital payment from 1 April 2026.*

Your password and your OTP are the two locks standing between a stranger and your money, your photos, and your identity. Understanding how to strengthen both is one of the highest-impact things any internet user can do.

Introduction

Authentication is the process of proving you are who you claim to be before a system grants you access. Every time you unlock your phone, log into email, or approve a UPI payment, you are authenticating yourself.

There are three broad categories — or "factors" — of authentication:

- **Something you know** — a password, PIN, or passphrase
- **Something you have** — your phone, a hardware security key, an OTP
- **Something you are** — your fingerprint, face, or other biometric trait

Using just one factor (like a password alone) is called **single-factor authentication**. Combining two or more factors from different categories is what makes **2FA** and **MFA** dramatically more secure — even if a criminal steals your password, they still cannot get in without your phone or fingerprint too.

Fundamental Concepts

The Three Authentication Factors

Factor Type	Description	Examples
Knowledge	Something only you should know	Password, PIN, passphrase, security question
Possession	Something only you should physically have	Phone (for OTP), hardware security key, smart card
Inherence	Something unique to your body	Fingerprint, face scan, iris scan, voice

Password vs Passphrase

Term	Meaning	Example Style
Password	A single string, often short and complex	`P@ssw0rd!23`
Passphrase	A longer string of random, unrelated words	`Correct-Horse-Battery-Staple-42`

Modern guidance (from the US National Institute of Standards and Technology, NIST) favours **passphrases**: they are longer, harder to crack, and easier for humans to remember than short, symbol-heavy passwords.

2FA vs MFA

- **2FA (Two-Factor Authentication):** Exactly two factors are used, typically a password plus an OTP or biometric.
- **MFA (Multi-Factor Authentication):** Two or more factors, which may include additional layers like a hardware key alongside a password and biometric.

All 2FA is a form of MFA, but not all MFA is limited to just two factors.

Complete Detailed Explanation

Part A — Building Genuinely Strong Passwords

Current NIST guidance (SP 800-63B, updated through 2025–2026) has shifted password advice significantly from older rules:

Old Advice (Outdated)	Current Best Practice
Use 8 characters with symbols/numbers/mixed case	Prioritise **length** — aim for 15+ characters where possible
Change your password every 90 days	Only change your password if there is evidence of a breach
Use complex, hard-to-remember strings	Use a memorable **passphrase** of random words
Rely on security questions ("mother's maiden name")	Avoid security questions/hints — they are guessable or researchable

Why length beats complexity: A long passphrase like `Tiger-Lamp-River-Cloud9` is far harder for a computer to brute-force than a short, complex password like `T!g3r@1`, while also being easier for you to remember.

Part B — Password Managers

A **password manager** is an encrypted digital vault that generates, stores, and automatically fills unique, strong passwords for every account you use — so you only need to remember one strong **master password**.

Advantage	Disadvantage
Generates truly random, unique passwords per site	If you forget your master password, recovery can be difficult
Removes the temptation to reuse passwords	A single point of failure if the master password is weak
Auto-fill reduces risk of typing passwords into fake/phishing sites	Requires trusting the password manager provider's security
Often flags weak or reused passwords across your accounts	—

Tip: Even a basic password manager, protected by a strong master passphrase and 2FA, is significantly safer than reusing a handful of passwords across dozens of accounts.

Part C — 2FA and MFA in Practice

Method	How It Works	Security Level
SMS-based OTP	A code sent via text message	Good, but vulnerable to SIM swap and interception
Authenticator App (TOTP)	A time-based code generated inside an app on your phone	Stronger — not dependent on your mobile network
Push Notification Approval	You approve a login attempt via a notification on a trusted device	Strong and convenient
Hardware Security Key	A physical USB/NFC device you plug in or tap	Very strong — highly resistant to phishing
Biometrics	Fingerprint or face recognition	Strong, but usually combined with another factor as backup

SMS OTPs remain useful and are still the most widely used second factor in India, but they are more vulnerable than app-based or hardware-based methods because SIM-swap fraud can redirect your OTPs to a criminal's device.

From **1 April 2026**, the Reserve Bank of India requires **two-factor authentication for every digital payment transaction** in India, with at least one factor being "dynamic" — unique and verifiable to that specific transaction — covering banks and non-bank payment providers alike.

Part D — OTP Safety

A **One-Time Password (OTP)** is a temporary, single-use code that acts as a dynamic second authentication factor. It is designed to be shared with no one except the system that generated it.

Common OTP Fraud Tactics in India:

- **Call-Merge Fraud:** A scammer tricks you into merging a call with your bank's actual OTP verification line, then captures the OTP read aloud by the automated system.
- **Fake Delivery/Refund Links:** A tiny "re-delivery fee" or "refund" payment link captures your card details and OTP for a small transaction, then uses the same session to drain much larger amounts.
- **Fake Customer Care Numbers:** Numbers found via unofficial Google searches connect you to fraudsters posing as your bank or e-commerce platform.
- **SIM Swap Fraud:** Criminals fraudulently get your number reissued on a new SIM, allowing them to receive your OTPs directly.

Important Terminologies

Term	Simple Meaning
Authentication	Proving you are who you claim to be
2FA	Two-Factor Authentication — exactly two verification methods
MFA	Multi-Factor Authentication — two or more verification methods
OTP	One-Time Password — a temporary, single-use code
Passphrase	A long password made of random, unrelated words
Password Manager	An encrypted vault that generates and stores unique passwords
TOTP	Time-based One-Time Password, generated inside an authenticator app
SIM Swap	Fraudulently transferring your phone number to a criminal's SIM card
Brute-Force Attack	Repeatedly guessing passwords until the correct one is found
Credential Stuffing	Using leaked username/password pairs from one breach to try logging into other sites
Biometric Authentication	Using a physical trait (fingerprint, face) to verify identity
Dynamic Authentication Factor	A factor unique and verifiable to one specific transaction (e.g., a transaction-specific OTP)

Step-by-Step Understanding

How to Set Up 2FA on Any Account

1. Go to the account's Security or Privacy settings
2. Look for "Two-Factor Authentication" or "2-Step Verification"
3. Choose your preferred method — authenticator app is recommended over SMS where available
4. Scan the QR code with an authenticator app, or register your phone number
5. Save the backup/recovery codes somewhere safe and offline
6. Test logging in again to confirm 2FA is working correctly

How to Create a Strong, Memorable Passphrase

1. Pick 4–5 random, unrelated words (avoid song lyrics, quotes, or names)
2. Add numbers or symbols between words, not just at the end
3. Make it at least 15 characters long overall
4. Avoid personal details (birthdays, pet names, family names)
5. Use a different passphrase for every important account, ideally via a password manager

Real-Life Indian Examples

(Widely reported public incidents, described for educational awareness.)

- **Call-Merge OTP Fraud (2025):** A rapidly spreading scam across India where fraudsters trick victims into merging calls with their bank's real automated OTP line, capturing the OTP read aloud and using it to authorise fraudulent transactions.
- **Fake Delivery-Fee OTP Scam (Banjara Hills, December 2025):** A resident lost approximately ₹2.49 lakh after paying a small "re-delivery fee" for a fake parcel delivery message — entering card details and an OTP that was then used for a much larger unauthorised transaction.
- **College Student OTP Scam (Bengaluru, April 2025):** A student lost close to ₹2.94 lakh after being tricked into sharing card details and an OTP through a fraudulent link, with the scam number going unreachable soon after.

Practical Scenarios

Scenario 1: You get an automated call from what sounds like your bank asking you to "press 1 to merge with customer support" during a suspicious transaction alert.
This is likely call-merge fraud. Hang up and call your bank directly using the number printed on your card or official app.

Scenario 2: A website you use daily suddenly forces you to answer "your first pet's name" to reset your password.
Security questions like this are often guessable from your social media. Prefer accounts that offer app-based 2FA instead.

Scenario 3: You've been reusing the same password across your email, banking, and shopping accounts for years.
If any one of those sites is breached, criminals will try that same password everywhere else. Move to unique passwords via a password manager.

Scenario 4: Your phone suddenly loses network signal for no clear reason, right after you received a strange call asking to "verify your SIM."
This can be a sign of SIM-swap fraud in progress. Contact your telecom provider and bank immediately.

Government Rules / Guidelines

- **Reserve Bank of India (RBI):** Issued the *Authentication Mechanisms for Digital Payment Transactions Directions, 2025*, mandating two-factor authentication for all digital payment transactions in India from 1 April 2026, with at least one authentication factor required to be dynamic (unique to that specific transaction).
- **NPCI (National Payments Corporation of India):** Oversees UPI security architecture, including transaction-specific PIN authentication for every UPI payment.
- **CERT-In:** Regularly issues advisories on password hygiene, credential-stuffing risks, and safe authentication practices for citizens and organisations.

Laws & Policies

Law / Provision	What It Covers
RBI Authentication Mechanisms for Digital Payment Transactions Directions, 2025	Mandates two-factor authentication (2FA) for all digital payments in India, effective 1 April 2026, with at least one dynamic factor
IT Act, 2000 — Section 66C	Punishes identity theft, including fraudulent use of passwords or authentication credentials
IT Act, 2000 — Section 66D	Punishes cheating by impersonation using a computer resource, covering OTP and phishing-based fraud
Digital Personal Data Protection Act, 2023	Requires Data Fiduciaries to implement "reasonable security safeguards," which includes robust authentication practices for systems storing personal data

Important Statistics

Metric	Figure
Projected cybercrime losses in India (2025)	Over ₹20,000 crore
RBI 2FA mandate for digital payments — effective date	1 April 2026
NIST recommended minimum password length (password-only login)	At least 15 characters
NIST minimum password length (used alongside MFA)	At least 8 characters
Bengaluru OTP scam cases (2022 → 2024)	Fell from 1,860 to 893 (a decline of nearly 52%) as scams shifted to more sophisticated tactics
Bengaluru investment-scam cases (2022 → 2024)	Rose from 411 to 5,707 (an increase of over 1,280%)

(Figures are approximate, drawn from RBI notifications, NIST publications, and city police data reported through 2025–2026.)

Best Practices

- Use a passphrase of 15+ characters made of random, unrelated words
- Use a password manager to generate and store unique passwords per account
- Enable app-based or hardware-key 2FA wherever available, not just SMS OTP
- Never share an OTP with anyone — including anyone claiming to be your bank
- Change a password immediately if you learn of a breach involving that service

- Save 2FA backup/recovery codes somewhere safe and offline
- Verify unfamiliar customer-care numbers only through official websites or apps

Common Mistakes

- Reusing the same password across multiple accounts
- Sharing an OTP over a phone call, SMS, or "call-merge" request
- Relying only on SMS OTP when a stronger 2FA method is available
- Using easily guessable passwords based on names, birthdays, or common words
- Ignoring a data breach notification and not changing the affected password
- Storing passwords in an unprotected notes app or written on paper near the device

Myths vs Facts

Myth	Fact
"A complex password with symbols is always stronger than a long one"	Length matters more than complexity; a long passphrase is generally stronger and easier to remember
"I should change my password every few months just to be safe"	Frequent forced changes are outdated advice; change only when there's evidence of a breach
"Password managers are risky because all my passwords are in one place"	A reputable, encrypted password manager with a strong master password and 2FA is far safer than reusing weak passwords
"SMS OTP is completely secure"	SIM-swap fraud and call-merge scams can compromise SMS OTPs; app-based or hardware 2FA is stronger
"My bank would never ask for my OTP, so if someone asks, it must be genuine"	Scammers impersonate banks precisely because people trust that framing — no genuine bank employee will ever ask for your OTP

Do's and Don'ts

Do	Don't
Use a unique passphrase for every important account	Don't reuse the same password across multiple sites
Enable app-based or hardware 2FA where offered	Don't rely solely on SMS OTP if a stronger option exists
Verify bank/customer-care contact through official channels	Don't trust caller ID alone or numbers found via casual search
Store backup codes offline and securely	Don't share OTPs with anyone, ever, for any reason
Update passwords immediately after a breach notice	Don't ignore breach or "unusual login" alerts

Safety Tips

For Banking & UPI
- Never share your OTP, UPI PIN, or CVV with anyone
- Set up transaction alerts and review them regularly
- Use your bank's official app rather than searching for "customer care" numbers online

For Everyday Accounts
- Turn on 2FA for email first — it's often the recovery gateway to all your other accounts
- Use a password manager instead of memorising dozens of passwords
- Review and remove access for apps/devices you no longer use

For Families & Seniors
- Explain clearly that no bank or government official will ever ask for an OTP over a call
- Help set up 2FA together rather than assuming it's "too technical"
- Encourage reporting suspicious calls immediately rather than trying to handle them alone

For Businesses/Professionals
- Enforce unique passwords and MFA across company accounts
- Avoid security questions with guessable/public answers
- Train employees to recognise call-merge and phishing-based OTP fraud

Practical Checklist

- ☐ Replaced weak/reused passwords with unique passphrases
- ☐ Set up a password manager for all important accounts
- ☐ Enabled 2FA on email, banking, and social media accounts
- ☐ Switched from SMS OTP to app-based 2FA where possible
- ☐ Saved backup/recovery codes securely offline
- ☐

Reviewed and removed old device/app access to key accounts

Shared OTP-safety awareness with family members

Quick Revision Notes

- Authentication factors: knowledge (password), possession (phone/OTP), inherence (biometric)
- NIST guidance: prioritise password length (15+ characters) over complexity; avoid forced periodic resets
- 2FA = exactly two factors; MFA = two or more factors
- App-based/hardware 2FA is stronger than SMS OTP, which is vulnerable to SIM swap and call-merge fraud
- RBI mandates 2FA for all digital payments in India from 1 April 2026
- Never share an OTP with anyone, under any circumstance

Key Takeaways

1. Longer passphrases beat short, complex passwords — length wins
2. A password manager removes the biggest single risk: password reuse
3. Not all 2FA is equal — app-based or hardware keys beat SMS OTP
4. OTP fraud in India increasingly relies on tricking you, not hacking technology
5. No genuine bank, government agency, or company will ever ask you to share an OTP

Glossary

- **2FA** — Two-Factor Authentication
- **Authentication** — The process of proving your identity to a system
- **Biometric** — A unique physical trait used for identity verification
- **Brute-Force Attack** — Repeated automated password guessing
- **Call-Merge Fraud** — A scam that merges a fraudulent call with a real OTP verification line
- **Credential Stuffing** — Using leaked login details from one breach to try other accounts
- **MFA** — Multi-Factor Authentication
- **OTP** — One-Time Password
- **Passphrase** — A long password made of multiple random words
- **Password Manager** — An encrypted vault for generating/storing passwords
- **SIM Swap** — Fraudulently transferring a victim's number to a new SIM
- **TOTP** — Time-based One-Time Password generated by an authenticator app

Frequently Asked Questions

1. What is authentication?
The process of proving you are who you claim to be before being granted access to a system.

2. What are the three types of authentication factors?
Something you know (password), something you have (phone/OTP), and something you are (biometric).

3. Is a long password always better than a complex one?
Generally yes — current guidance favours long passphrases over short, symbol-heavy passwords.

4. How often should I change my password?
Only when there is evidence of a breach — not on a routine schedule, according to current best practice.

5. What is a password manager?
An encrypted digital vault that generates and stores a unique password for every account you use.

6. Are password managers safe?
Yes, when reputable and protected by a strong master password plus 2FA — safer than reusing weak passwords.

7. What is the difference between 2FA and MFA?
2FA uses exactly two authentication factors; MFA uses two or more.

8. Is SMS OTP secure?
It's reasonably secure but vulnerable to SIM-swap and call-merge fraud — app-based or hardware 2FA is stronger.

9. What is call-merge fraud?
A scam where fraudsters trick you into merging your call with your bank's real OTP line to capture the OTP.

10. Should I ever share my OTP with my bank?
No. No genuine bank employee will ever ask you to share your OTP over a call, SMS, or chat.

11. What is a passphrase?
A long password made of several random, unrelated words, which is easier to remember and harder to crack.

12. What is SIM-swap fraud?
When criminals fraudulently transfer your phone number to a SIM card they control, to intercept your OTPs.

13. When does RBI's 2FA mandate for digital payments take effect?
From 1 April 2026, covering all digital payment transactions in India.

14. Can I use the same password for multiple accounts if it's very strong?
No — if one site is breached, attackers will try that password on your other accounts too (credential stuffing).

15. What should I do if I receive a data breach notification?
Change the password for that account immediately, and for any other account using the same password.

16. Are security questions like "mother's maiden name" safe?
No — such answers are often guessable or discoverable via social media, so current guidance discourages them.

17. What is an authenticator app?
An app that generates a time-based one-time code (TOTP) on your device, used as a stronger alternative to SMS OTP.

18. What should I do if I suspect SIM-swap fraud?
Contact your telecom provider and bank immediately if your phone unexpectedly loses signal after a suspicious call.

19. Is biometric authentication foolproof?
It's strong but usually best combined with another factor, since biometric data cannot be changed like a password.

20. What is a dynamic authentication factor?
An authentication factor that is unique and verifiable to one specific transaction, such as a transaction-specific OTP.

21. Where can I report OTP or authentication-related fraud in India?
Through the National Cyber Crime Reporting Portal (cybercrime.gov.in) or the 1930 helpline.

22. Do password managers protect against phishing sites?
Largely yes — most auto-fill only on the correct, saved website domain, helping you notice fake look-alike sites.

Suggested Infographics, Flowcharts & Illustrations

(For JanGyan design team — placement suggestions only; no images generated here)

- **"Three Authentication Factors" icon diagram** → after "Fundamental Concepts"
- **Password vs Passphrase strength comparison bar chart** → within "Complete Detailed Explanation, Part A"
- **Flowchart: "How Call-Merge OTP Fraud Works"** → within "Real-Life Indian Examples"
- **2FA methods ranked by strength (visual ladder)** → within "Complete Detailed Explanation, Part C"
- **"Never Share Your OTP" emergency callout card** → placed prominently near Practical Checklist

---

Official References

- Reserve Bank of India — Authentication Mechanisms for Digital Payment Transactions Directions, 2025
- National Institute of Standards and Technology (NIST) — Special Publication 800-63B (Digital Identity Guidelines)
- Information Technology Act, 2000 (as amended), India Code portal
- Digital Personal Data Protection Act, 2023 — Ministry of Electronics and Information Technology (MeitY)
- National Payments Corporation of India (NPCI) — UPI security guidelines
- Indian Computer Emergency Response Team (CERT-In) — password and authentication advisories

---

Official Government Website Links

- Reserve Bank of India: **https://www.rbi.org.in**
- NPCI (UPI): **https://www.npci.org.in**
- CERT-In: **https://www.cert-in.org.in**
- MeitY: **https://www.meity.gov.in**
- National Cyber Crime Reporting Portal: **https://cybercrime.gov.in**
- Digital India: **https://www.digitalindia.gov.in**

Cybercrime Helpline (24×7, Toll-Free): 1930

Conclusion

Your password and your OTP are the two gates guarding everything valuable in your digital life. A strong, unique passphrase — backed by a password manager and real Two-Factor Authentication — turns a criminal's easiest opportunity into a dead end. And remembering one simple rule, that you never, ever share an OTP with anyone, closes the door on the most common fraud tactic in India today.

This is only the next step in your Cyber Safety journey with JanGyan. Stay alert, stay informed, and remember: **your OTP is not for sharing — not with anyone, not ever.**

JanGyan — Learn Without Limits
Module 3 of the Cyber Safety & Digital Security Category